

DAY 28 ASSIGNMENT

SQL INJECTION FUNDAMENTALS & SAFE LAB REPORT

Name:- Rishabh Raj

1. What is SQL?

SQL (Structured Query Language) is a language used to create, read, update, and delete data in relational databases. It is also used to define database structures and control database operations.

2. What is SQL Injection?

SQL Injection (SQLi) is a vulnerability in which untrusted user input is incorporated into a database query in an unsafe way, allowing the input to change the intended SQL query logic.

3. What is a WHERE clause?

A WHERE clause filters database records according to a condition. For example, `SELECT * FROM products WHERE category = 'Books';` returns records that satisfy the specified condition.

4. Explain AND and OR in SQL conditions.

AND requires all connected conditions to be true. OR requires at least one connected condition to be true. They control how multiple conditions are combined in a query.

5. Why is 1=1 considered an always-true condition?

Because the value 1 is equal to 1, the comparison evaluates to TRUE. When introduced into a vulnerable query, such a condition can make a filter condition always true.

6. What is SQL comment syntax used for conceptually?

SQL comments tell the database engine to ignore the commented portion of a statement. In SQL Injection testing, a comment can conceptually prevent the remainder of an original query from affecting the injected condition. The exact comment syntax depends on the database.

7. Explain why raw user input should not be concatenated directly into SQL queries.

Direct concatenation mixes data with SQL syntax. If input is not safely handled, a user may alter the structure or logic of the query. This can lead to SQL Injection and unauthorized access to database information.

8. What is a parameterized query?

A parameterized query separates SQL code from user-supplied values by using placeholders. The database treats the supplied values as data rather than executable SQL syntax.

9. What is a prepared statement?

A prepared statement is a database statement whose SQL structure is prepared separately from its input values. Parameters are then supplied safely when the statement is executed, helping prevent SQL Injection.

10. Why does Least Privilege matter for database accounts?

Least Privilege means a database account receives only the permissions required for its task. If an application is compromised, limited privileges reduce the amount of data or functionality an attacker can access.

1. Which parameter was vulnerable?

The product-category filter parameter (commonly named 'category') was vulnerable because its value was incorporated into the SQL WHERE clause without safe parameterization.

2. What product category did you initially select?

I initially selected a normal product category from the lab's category filter. In the standard PortSwigger lab, the category can be selected from the available categories such as 'Gifts'.

3. What was the purpose of the released = 1 condition?

The intended lab test uses a condition that evaluates as true. This demonstrates that the application can be made to treat the WHERE condition as true instead of restricting results to the original category.

4. What controlled training input changed the query behavior?

A controlled SQL Injection test input using a true condition was supplied to the vulnerable category parameter. In the standard lab exercise, the training payload is conceptually represented by an input such as: ' OR 1=1—

5. What does the 1=1 condition mean?

It is a Boolean expression that evaluates to TRUE. In a vulnerable WHERE clause, adding a true condition can cause the database to return records that would otherwise be filtered out.

6. Why did additional/unreleased products become visible?

Because the injected true condition changed the filtering logic of the vulnerable WHERE clause. As a result, products outside the originally selected category could be returned.

7. Which Burp Suite feature did you use to resend the request?

Burp Suite Repeater was used to resend the HTTP request after modifying the training parameter.

8. What changed between the original response and modified training response?

The original response displayed products limited by the selected category. After the controlled input changed the SQL condition, the modified response displayed additional products, demonstrating that the WHERE-clause logic had been altered.

9. Did PortSwigger mark the lab as Solved?

Yes. The lab is considered solved when the hidden/unreleased products are successfully retrieved using the intended controlled SQL Injection technique.

10. Include one screenshot showing successful lab completion.

Screenshot placeholder: Insert your own PortSwigger Web Security Academy screenshot here showing the lab marked 'Solved'. The provided assignment images do not contain a successful-lab screenshot, so it should not be fabricated.